Remediation Roadmap

Total actions	Critical	High	Status
12	1	11	All actions open

R-006 Vulnerability management

Control ID: CTL-07

Priority: Critical

Target date: 11/13/26

Status: Open

Recommended action: Remediate or formally mitigate overdue VUL-02 and record a current target date. Verify VUL-01’s outcome against its October 20 target and address any unresolved finding. Confirm whether the Admin host is in scope; obtain scan evidence if applicable or document a justified exclusion. Reassess VUL-03 and document any renewed exception approval and compensating controls.

Accountable owner: Vulnerability Management Owner with affected system owners

Closure evidence: VUL-01 outcome verification; closure or formal mitigation records for VUL-01 and VUL-02, with updated targets where needed; a documented Admin-host scope decision supported by scan evidence or a justified exclusion; VUL-03 reassessment and any approved renewed exception with compensating controls.

Key dependencies: Affected system owners; vulnerability scanning coverage

R-001 Privileged access and MFA

Control ID: CTL-05

Priority: High

Target date: 11/13/26

Status: Open

Recommended action: Verify and enforce MFA for PA-010. Validate authorization and ownership for PA-010 and PA-012. Document authentication safeguards for PA-012.

Accountable owner: Identity and Access Management / Privileged Access Owner

Closure evidence: MFA enforcement evidence; authorization and ownership records for PA-010 and PA-012; documented PA-012 safeguards.

Key dependencies: Identity and Access Management; account owners

R-004 Terminated-user access

Control ID: CTL-04 **Priority:** High

Target date: 11/13/26 **Status:** Open

Recommended action: Immediately verify and remove access for USR-023 and USR-024 where no longer required. Reconcile termination records to active accounts and require documented follow-up for unreviewed accounts.

Accountable owner: Access Management with HR and relevant system owners

Closure evidence: Account-removal or retention decisions; termination-to-account reconciliation; documented follow-up evidence.

Key dependencies: HR termination data; relevant system owners

R-002 Critical vendor oversight

Control ID: CTL-03 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Obtain and review the payment processor’s current assurance report. Resolve and document incident-notification terms. Document formal risk acceptance if the terms cannot be resolved within the target period.

Accountable owner: Security, with Legal support for incident-notification terms

Closure evidence: Current assurance report and review record; finalized incident-notification terms or approved risk acceptance.

Key dependencies: Payment processor; Legal

R-003 CI/CD asset ownership

Control ID: CTL-02 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Assign a CI/CD platform owner, complete and document an asset review, and establish periodic review requirements for in-scope assets.

Accountable owner: Engineering Leadership / Designated CI/CD asset owner

Closure evidence: Named asset owner; completed asset-review record; periodic review standard and evidence.

Key dependencies: Engineering Leadership; CI/CD platform owner

R-005 Change management evidence

Control ID: CTL-06 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Require approval before normal production deployments, test evidence before closure, and documented post-implementation reviews for emergency changes. Investigate CHG-101 and CHG-103 follow-ups.

Accountable owner: Change Management Owner with Engineering support

Closure evidence: Revised workflow requirements; approval, testing, and emergency-review evidence; documented CHG-101 and CHG-103 outcomes.

Key dependencies: Engineering; change approvers

R-007 Logging and monitoring

Control ID: CTL-08 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Review database logging configuration, confirm support-console scope, centralize logging where required, define retention requirements, and require documented rationale and investigation notes for high-severity alert closure.

Accountable owner: Security Operations / Logging and Monitoring Owner

Closure evidence: Database logging configuration; scope confirmation; retention standard; high-severity alert closure records.

Key dependencies: Database and support-console owners

R-008 Incident response follow-up

Control ID: CTL-09 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Document root-cause analysis for INC-01, resolve and track TTX-01 actions, conduct and document a retest, and add specific payment-processor coordination procedures to the response plan.

Accountable owner: Incident Response Owner with Security and processor relationship owners

Closure evidence: INC-01 root-cause analysis; closed tabletop actions; retest record; updated response-plan procedures.

Key dependencies: Security; payment processor relationship owners

R-009 Sensitive data protection

Control ID: CTL-10 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Map the support-export data flow, validate and document analytics-store encryption at rest, define approved retention requirements, and apply and evidence retention controls for affected exports.

Accountable owner: Data Protection Owner with Analytics and Support Operations owners

Closure evidence: Data-flow map; encryption-at-rest evidence; approved retention rationale and applied export controls.

Key dependencies: Analytics; Support Operations

R-010 Backup and recovery

Control ID: CTL-11 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Verify backup coverage for identity configuration, define and approve recovery objectives, test restores against those objectives, and complete the missing backup-administrator access review.

Accountable owner: Backup and Disaster Recovery Owner with Identity and system owners

Closure evidence: Identity backup evidence; approved recovery objectives; restore-test results; completed administrator access review.

Key dependencies: Identity; critical-system owners

R-011 Payment transaction integrity

Control ID: CTL-12 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Resolve and document REC-02, document REC-03’s resolution reason, require retained independent review for payment-routing changes, and obtain technical operating evidence for transaction controls.

Accountable owner: Payment Operations Owner with Change Management support

Closure evidence: REC-02 and REC-03 records; routing-change independent-review evidence; technical control-operation evidence.

Key dependencies: Payment Operations; Change Management

R-012 Governance and third-party accountability

Control ID: CTL-01 **Priority:** High

Target date: 11/27/26 **Status:** Open

Recommended action: Assign one accountable owner for third-party risk, complete and document the access-policy review, and close or formally reprioritize the overdue high-priority risk committee action.

Accountable owner: Director Security with assigned Third-Party Risk Owner

Closure evidence: Named accountable owner; completed policy review; closed or formally reprioritized committee action with target date.

Key dependencies: Director Security; Third-Party Risk Owner

Roadmap Notes

Use this roadmap to track remediation activity. Do not mark an action complete until the listed closure evidence is available and reviewed.

Method and assumptions

1. Recommended actions, owners, and target dates are drawn from the Risk Register.

2. Priority follows the recorded inherent level. The source identifies R-006 as Critical; the remaining risks are High.

3. All actions remain Open because the Risk Register does not provide remediation-completion evidence.

4. Closure evidence and key dependencies organize the register’s remediation expectations into an execution-ready view. They do not change the recorded risk scores or residual assessment.

5. This roadmap tracks prioritized actions for the risks in the Risk Register. Additional recommendations remain in the Control Assessment Matrix. Completing these roadmap actions does not by itself establish that every control gap is closed.